Rails Health Audit — example-unhealthy-project

Generated 2026-06-23 15:20. Static scan + runtime checks. Full raw tool output is in `raw_original_result/`.

1. Overview (every check, most severe first)

Priority	Category	Tool	Finding	Raw output
🔴 1	Security	brakeman	4 warning(s)	`raw_original_result/brakeman.txt`
🔴 1	Security	bundler-audit	8 vulnerable advisory(ies)	`raw_original_result/bundler-audit.txt`
🔴 1	Compliance	license_finder	73	`raw_original_result/license_finder.txt`
🟡 3	Performance	fasterer	5 speed suggestion(s)	`raw_original_result/fasterer.txt`
🟡 4	Maintainability	rubycritic	score 95.48, 31 smell(s)	`raw_original_result/rubycritic.txt`
🟡 4	Rails conventions	rails_best_practices	19 warning(s)	`raw_original_result/rails_best_practices.txt`
⚪ 4	Maintainability	rubocop	27 offense(s)	`raw_original_result/rubocop.txt`
⚪ 4	Maintainability	erb_lint	8 ERB offense(s)	`raw_original_result/erb_lint.txt`
⚪ 5	Tech debt	bundle outdated	2	`raw_original_result/outdated.txt`
🔴 2	Data correctness	active_record_doctor	7 issue(s)	`raw_original_result/pass2_ar_doctor.txt`
🟡 3	Performance	lol_dba	2 missing index(es)	`raw_original_result/pass2_lol_dba.txt`

Legend — 🔴 must fix (security / data) · 🟡 should fix (correctness / maintainability) · ⚪ nice to have (style / freshness).

> **A ⚠️ skipped check is NOT a pass.** It means the tool could not run in this environment, not that there is nothing wrong. license_finder needs a real `bundle install`; bundle outdated needs the project's own Ruby (this run used a different Ruby than the project pins). Re-run both in the project's environment to get a real result. *(In this example both ran — it is a real, bundle-installed Rails 8 app — so neither is skipped.)*

2. Action plan

> **How to read this — cut noise with confidence/criticality:** static tools over-report. brakeman tags each warning High / Medium / Weak confidence — fix the **High** ones first; Weak ones are often false positives. bundler-audit tags each advisory Critical / High / Medium — triage **Critical/High**, don't treat all 100+ as equal. So a raw count (e.g. "137 advisories") is a starting point, not 137 separate jobs.

Severity first. Cover every 🔴 and 🟡 finding (one row each); collapse the ⚪ style-level findings into a single row. Use `<br>` *for line breaks inside a cell.*

#	Pri	Issue (tool, `file:line`)	Solution	Effort	Raw
1	🔴	**Command injection** (brakeman, High) `app/controllers/products_controller.rb:28` — `system("convert #{thumb} …")` shells out with user input.	Never interpolate params into a shell. Use an image library (`image_processing` / `vips`) or pass args as an array so no shell is invoked.	M	`raw_original_result/brakeman.txt`
2	🔴	**SQL injection** (brakeman, High) `app/controllers/products_controller.rb:8` (`where("… #{params[:q]} …")`) and `:10`	Parameterize: `where("name LIKE ?", "%#{q}%")`; whitelist `params[:sort]` against allowed columns.	M	`raw_original_result/brakeman.txt`

#	Pri	Issue (tool, `file:line`)	Solution	Effort	Raw
		(`connection.execute` with interpolation).			
3	🔴	**XSS** (brakeman, High) `app/views/products/index.html.erb:4` — `params[:q].html_safe` renders raw user input.	Drop `.html_safe`; let Rails auto-escape. If HTML is needed, `sanitize` an allow-list.	S	`raw_original_result/brakeman.txt`
4	🔴	**Vulnerable gem: jwt 2.3.0** (bundler-audit, High) CVE-2026-45363 — empty-key HMAC signature bypass.	Upgrade `gem "jwt", ">= 3.2.0"`, then `bundle update jwt`.	S	`raw_original_result/bundler-audit.txt`
5	🔴	**Vulnerable gem: rexml 3.2.4** (bundler-audit, 7 advisories incl. High ReDoS GHSA-2rxp-v6pw-ch6m).	Upgrade `gem "rexml", ">= 3.3.9"`, then `bundle update rexml`. One bump clears all 7.	S	`raw_original_result/bundler-audit.txt`
6	🔴	**License compliance** (license_finder) 73 dependencies have no approval decision.	Set an allowed-license policy; approve/replace anything copyleft (GPL) that conflicts with the product license.	M	`raw_original_result/license_finder.txt`
7	🔴	**Data integrity** (active_record_doctor — runtime, 7 issues) 2 missing foreign keys (`products.owner_id`, `tags.product_id`); 2 columns need NOT NULL; `products.sku` needs a unique index.	Add migrations: `add_foreign_key`, `change_column_null`, `add_index … unique: true`. See §3.	M	`raw_original_result/pass2_ar_doctor.txt`
8	🟡	`rescue Exception` (rails_best_practices) `app/controllers/products_controller.rb:35` swallows every error, incl. signals.	Rescue `StandardError` (or a specific class) and re-raise / report the rest.	S	`raw_original_result/rails_best_practices.txt`
9	🟡	**Fat controller / logic in view** (rails_best_practices) `products_controller.rb:14,`	Move create/update body into a service or model method; move	M	`raw_original_result/rails_best_p`

#	Pri	Issue (tool, `file:line`)	Solution	Effort	Raw
		`41` (`@product` used >4×) and `index.html.erb:13`.	the view conditional into a model helper.		`ractices.txt`
10	🟡	**Missing indexes** (lol_dba — runtime) 2 association columns (`owner_id`, `product_id`) have no index.	`add_index` on each foreign-key column; pairs with the FK work in row 7.	S	`raw_original_result/pass2_lol_dba.txt`
11	🟡	**Maintainability smells** (rubycritic, 31) `app/models/product.rb` — Law of Demeter (`owner.address.city`), feature envy, complex `#s`.	Add delegations (`delegate :city, to: :address`); rename/extract `#s`; de-duplicate the `create`/`update` blocks.	M	`raw_original_result/rubycritic.txt`
12	🟡	**Slow Ruby idioms** (fasterer, 5) `app/models/report.rb:6` (`select{}.first` → `detect`), `:16` (`reverse.each` → `reverse_each`); plus `config/*`.	Swap to the faster idiom each line names — trivial, mechanical.	S	`raw_original_result/fasterer.txt`
13	⚪	**Style** (rubocop 27 + erb_lint 8) spacing, tag formatting, layout across `app/`.	Auto-fix: `rubocop -A` and `erb_lint --autocorrect`, then commit the diff.	S	`raw_original_result/rubocop.txt` `raw_original_result/erb_lint.txt`

3. Phase 2 — runtime checks (ran against the app + DB)

Booted the app against its database (2026-06-23 15:20). Raw output in `raw_original_result/`.

Data correctness & indexing

Detector	Findings
missing_unique_indexes	1
missing_non_null_constraint	2
missing_foreign_keys	2
unindexed_foreign_keys	2
incorrect_dependent_option	0
lol_dba (missing indexes)	2

See `raw_original_result/pass2_ar_doctor.txt` and `raw_original_result/pass2_lol_dba.txt` for the specific tables/columns.

Still manual (need the app exercised, not just booted)

- **N+1 queries** — add `bullet` (dev/test) or `prosopite`, then run the suite or click through the app; N+1s only surface on code paths that actually execute.
- **Test coverage** — run the suite with `simplecov`, read `coverage/index.html`.